Information Security Policy

PayPorter Local LLM – Security Policy Test Document

Bu doküman, PayPorter için geliştirilen yerel LLM/RAG sisteminin PDF okuma ve güvenlik politikası üzerinden soru-cevap yeteneklerini test etmek amacıyla hazırlanmış örnek bir politikadır. Gerçek kurum politikası yerine test verisi olarak kullanılmalıdır.

1. Amaç ve Kapsam

Bu politikanın amacı; şirket bilgilerini, kullanıcı verilerini, yazılım sistemlerini ve erişim bilgilerini yetkisiz erişim, değiştirme, ifşa, kayıp ve kötüye kullanıma karşı korumaktır. Politika çalışanları, stajyerleri, yüklenicileri, uygulamaları, sunucuları, istemci cihazlarını ve şirket tarafından kullanılan bulut veya yerel sistemleri kapsar.

2. Erişim Kontrolü

Sistem erişimleri en az ayrıcalık (least privilege) prensibine göre verilmelidir. Kullanıcı yalnızca görevi için gerekli kaynaklara erişebilmelidir. Yönetici yetkileri standart kullanıcı hesaplarından ayrılmalı, işten ayrılan veya görevi değişen kişilerin erişimleri zamanında gözden geçirilmeli ve kaldırılmalıdır.

3. Kimlik Doğrulama ve Parola Güvenliği

Kullanıcı hesaplarında güçlü ve benzersiz parolalar kullanılmalıdır. Parolalar başka kullanıcılarla paylaşılmamalı veya düz metin dosyalarda saklanmamalıdır. Kritik sistemlerde mümkün olduğunda çok faktörlü kimlik doğrulama (MFA) kullanılmalıdır. Varsayılan parolalar sistem devreye alınmadan önce değiştirilmelidir.

4. API Anahtarları ve Gizli Bilgiler

API key, access token, private key, veritabanı parolası ve benzeri gizli bilgiler kaynak kod içine hard-code edilmemelidir. Bu değerler environment variable, secret manager veya kurumun onayladığı güvenli bir yapı üzerinden yönetilmelidir. Gizli bilgiler Git repository, log dosyası veya ekran görüntüsü üzerinden paylaşılmamalıdır.

5. Veri Koruma

Hassas veriler yalnızca iş amacı için gerekli olduğu ölçüde işlenmelidir. Veriler aktarım sırasında ve gerektiğinde depolama sırasında uygun şifreleme yöntemleriyle korunmalıdır. Kişisel veya finansal bilgiler yetkisiz kişilerle paylaşılmamalı; test ortamlarında gerçek müşteri verisi kullanılması gerekiyorsa gerekli maskeleme veya anonimleştirme uygulanmalıdır.

6. Güvenli Yazılım Geliştirme

Kullanıcı girdileri doğrulanmalı ve güvenilmeyen veri doğrudan komut, HTML veya SQL sorgusuna eklenmemelidir. SQL işlemlerinde parametreli sorgular tercih edilmelidir. Bağımlılıklar güncel tutulmalı, güvenlik açığı bulunan paketler değerlendirilmelidir. Kod değişiklikleri mümkün olduğunda code review ve test sürecinden geçirilmelidir.

7. Loglama ve İzleme

Başarısız girişler, yetki değişiklikleri, kritik sistem hataları ve önemli güvenlik olayları uygun şekilde loglanmalıdır. Ancak parola, erişim tokenı, kart verisi veya diğer gizli bilgiler loglara açık şekilde yazılmamalıdır. Loglara erişim sınırlandırılmalı ve olağandışı aktiviteler düzenli olarak incelenmelidir.

8. Cihaz ve Uç Nokta Güvenliği

Şirket cihazlarında desteklenen işletim sistemi ve güvenlik güncellemeleri kullanılmalıdır. Ekran kilidi etkin olmalı ve cihaz gözetimsiz bırakıldığında oturum kilitlenmelidir. Bilinmeyen USB cihazları ve yetkisiz yazılımlar güvenlik riski oluşturabileceğinden kurum kurallarına uygun şekilde sınırlandırılmalıdır.

9. Ağ Güvenliği

Sistemler yalnızca ihtiyaç duyulan ağ servislerini ve portları açık tutmalıdır. Güvenilmeyen ağlardan kurumsal kaynaklara erişimde güvenli bağlantı yöntemleri kullanılmalıdır. Firewall kuralları, VPN erişimleri ve uzak bağlantılar periyodik olarak gözden geçirilmelidir.

10. Olay Bildirimi

Şüpheli e-posta, yetkisiz erişim, veri sızıntısı, zararlı yazılım, kayıp cihaz veya ele geçirilmiş hesap şüphesi mümkün olan en kısa sürede sorumlu güvenlik veya BT ekibine bildirilmelidir. Kullanıcılar güvenlik olaylarını kendi başlarına gizlemeye veya kanıtları silmeye çalışmamalıdır.

11. Yedekleme ve İş Sürekliliği

Kritik veriler ve sistem yapılandırmaları belirlenen plana göre yedeklenmelidir. Yedeklerin yalnızca oluşturulması yeterli değildir; gerektiğinde geri yüklenebildiği düzenli olarak doğrulanmalıdır. Kritik sistemler için kesinti durumunda izlenecek temel kurtarma adımları dokümante edilmelidir.

12. Yapay Zeka ve Local LLM Güvenliği

Yerel LLM sistemine yüklenen dokümanlar yalnızca yetkili kullanıcılar tarafından erişilebilir olmalıdır. RAG sisteminde indekslenen belgelerin erişim izinleri korunmalı ve bir kullanıcının yetkisi olmayan belge parçaları cevap bağlamına eklenmemelidir. Model promptları, vektör veritabanı ve kaynak dokümanlar hassas bilgi içerebileceğinden uygun erişim kontrolleri uygulanmalıdır. Model çıktıları otomatik olarak doğru veya güvenli kabul edilmemeli; kritik işlemlerde doğrulama yapılmalıdır.

13. Politika İhlalleri

Bu politikaya aykırı durumlar tespit edildiğinde olayın kapsamı değerlendirilmeli, gerekli erişimler sınırlandırılmalı ve ilgili ekip bilgilendirilmelidir. Tekrarlanan veya ciddi ihlaller kurumun iç prosedürleri doğrultusunda ele alınmalıdır.

14. Security Policy – Hızlı Kontrol Tablosu

Kontrol	Politika
Parola paylaşımı	Yasaktır
API key'i kaynak koda yazmak	Yasaktır
MFA	Kritik sistemlerde önerilir / uygulanmalıdır
SQL sorguları	Parametreli sorgular tercih edilmelidir
Hassas veriyi loglamak	Yasaktır
Yetki modeli	Least privilege
Şüpheli güvenlik olayı	Güvenlik/BT ekibine bildirilmelidir
Local LLM belge erişimi	Belge yetkileri korunmalıdır

15. LLM/RAG Test Soruları

1. API anahtarları kaynak kod içinde tutulabilir mi?
2. Least privilege prensibi ne anlama geliyor?
3. Kritik sistemlerde hangi ek kimlik doğrulama yöntemi öneriliyor?
4. Hassas bilgiler log dosyalarına yazılabilir mi?
5. SQL injection riskini azaltmak için hangi yaklaşım öneriliyor?
6. Bir çalışan şirketten ayrıldığında erişimleriyle ilgili ne yapılmalıdır?
7. Şüpheli bir güvenlik olayı fark edildiğinde ne yapılmalıdır?
8. Local LLM sisteminde belge erişim izinleri neden korunmalıdır?
9. Model çıktıları kritik işlemlerde doğrudan doğru kabul edilmeli midir?
10. Yedekleme sisteminin çalıştığı nasıl doğrulanmalıdır?

Beklenen test: PDF sisteme yüklendikten ve indekslendikten sonra modelin bu sorulara dokümandaki bilgileri temel alarak cevap vermesi ve özellikle Security Policy içindeki ilgili bölümü doğru şekilde retrieve edebilmesi beklenir.